

EQUINESYNC FOUNDATIONAL CANON VENDOR SECURITY Every Horse. Every Task. In Sync.	TIER 3 FOUNDATIONAL DOMAIN CANON CONSTITUTIONAL GOVERNANCE Master Vendor Security and Supply Chain Model VERSION 2.0 Founder Accepted Constitutional Canon Controlled adoption and repository lock remain pending. No implementation, vendor activation, contract execution, data disclosure, production mutation, or public-launch authority is created by founder acceptance alone. LIFECYCLE Founder accepted; controlled adoption and lock pending AUTHORITY Controlling constitutional text; implementation authority remains false FOUNDER POSTURE Accepted July 13, 2026
---	---

Founder Approval and Authority Status

Field	Controlling Value
Founder Approval Status	**FOUNDER APPROVED**
Founder Approval Date	**July 13, 2026**
Constitutional Status	**CONTROLLING CANON**
Canon Adoption	**PENDING SEPARATE ADOPTION EVIDENCE**
Canon Lock	**NOT LOCKED BY THIS DIRECTIVE**
Implementation Authority	**FALSE**
Schema / Migration Authority	**FALSE**
Runtime Activation Authority	**FALSE**
Production Authority	**FALSE**
External-Provider Activation Authority	**FALSE**
Public-Claims Authority	**FALSE**
Public-Launch Authority	**FALSE**

Founder approval establishes the controlling substantive constitutional text. Adoption, lock, implementation, runtime, production, provider, public-claims, and launch authority remain separately gated.

---	---
	FOUNDER ACCEPTANCE NOTICE: This document has been accepted by the Founder as controlling constitutional text. Controlled adoption and repository lock remain pending. It is not implemented and creates no vendor approval, contract execution, vendor activation, data disclosure, migration, production mutation, public trust claim, or public-launch authority.

Document Control

Field	Value
Document Type	Tier 3 Foundational Domain Canon
Canonical Name	Master Vendor Security and Supply Chain Model
Version	2.0
Lifecycle State	FOUNDER_ACCEPTED_CONTROLLED_ADOPTION_AND_LOCK_PENDING
Founder Posture	Founder accepted
Constitutional Authority	Controlling founder-approved canon; terminal repository lock not verified in this document
Adoption Authorized	Yes, through controlled adoption process
Lock Achieved	No

Implementation Authorized	No
Vendor Approval Authorized	No
Contract Execution Authorized	No
Vendor Activation Authorized	No
Integration Activation Authorized	No
Data Disclosure Authorized	No
Vendor Migration Authorized	No
Vendor Termination Authorized	No
Production Mutation Authorized	No
Public Trust Claim Authorized	No
Public Launch Authorized	No
Parent Authority	MASTER_SECURITY_AND_TRUST_MODEL_V2_0.md
Prior Version	Initial Version 2.0; no prior adopted version
Primary Steward	Founder until formally delegated

Required Cross-Canon Dependencies

- MASTER_SECURITY_AND_TRUST_MODEL_V2_0.md
- MASTER_ACCESS_CONTROL_AND_AUTHORIZATION_MODEL_V2_0.md
- MASTER_SECURITY_INCIDENT_RESPONSE_AND_DISCLOSURE_MODEL_V2_1.md
- MASTER_DATA_PROTECTION_ENCRYPTION_AND_KEY_MANAGEMENT_MODEL_V2_0.md
- MASTER_PLATFORM_RESILIENCE_BACKUP_AND_RECOVERY_MODEL_V2_0.md
- Master Privacy and Data Protection Model
- Master External Architecture and Adapter Model
- Master Audit Event and Evidence Model
- Master Claims and Retention Model
- Master Record Stewardship and Retention Model
- Master Financial Truth and Responsibility Model
- Master Identity, Account, and Actor Model
- Master Communication, Notification, and Notice Model
- Master AI Governance and Decision Boundary Model
- Master Platform Operations, Reliability, and Release Model
- Governing offline synchronization canon
- Controlling minors and safeguarding governance
- Governing agreement and consent canon
- Master EquineSync Implementation Atlas and all applicable implementation gates

Executive Constitutional Rule

EquineSync may use vendors and software dependencies only within a defined, evidence-backed, minimum-necessary, revocable, and exit-capable trust boundary. No vendor, certification, marketplace listing, contract, integration, or technical convenience creates authority to access customer data, alter authoritative records, weaken tenant isolation, train shared models, or enter production without separate governed approval and validation.

1. Constitutional Purpose

This Master Vendor Security and Supply Chain Model establishes the controlling governance framework for evaluating, selecting, contracting with, onboarding, monitoring, restricting, replacing, and terminating vendors and supply-chain dependencies used by EquineSync.

It governs relationships involving:

- cloud infrastructure;
- software-as-a-service providers;
- payment processors;
- identity providers;
- communication providers;
- analytics services;
- AI and model providers;
- source-code hosts;
- build systems;
- package registries;
- open-source libraries;
- mobile application distribution;
- monitoring and logging services;
- customer-support platforms;
- contractors;
- consultants;
- subprocessors;
- fourth-party providers;
- data-storage providers;
- integration partners;
- professional advisers;
- security-testing providers;
- recovery and backup providers.

A vendor relationship is not merely a commercial purchase.

A vendor may obtain the ability to:

- access customer information;
- affect authoritative records;
- influence authentication;
- process payments;
- deliver communications;
- alter software;
- interrupt horse-care operations;
- compromise tenant isolation;
- preserve or destroy evidence;
- affect legal and regulatory obligations;
- create concentration and continuity risk.

Vendor and supply-chain governance shall therefore be treated as constitutional trust governance.

2. Governing Principles

EquineSync shall govern vendors and supply-chain dependencies according to these principles:

1. no vendor receives trust merely because it is popular, large, certified, or already in use;

2. review depth shall increase with data sensitivity, authority, criticality, and exit difficulty;
3. vendors shall receive only minimum-necessary access and information;
4. customer operational data shall not be sold, licensed, or used for unrelated monetization;
5. customer data shall not train shared or general AI models;
6. tenant isolation must extend through vendor processing;
7. vendor security claims require evidence;
8. contracts must reflect actual technical and operational risk;
9. critical vendors require continuity and exit planning before activation;
10. subprocessors and fourth parties must not become invisible trust pathways;
11. source code and build dependencies are part of the security perimeter;
12. vendor convenience does not override privacy, safeguarding, financial, audit, or evidentiary requirements;
13. provider neutrality and migration capability shall be preserved where reasonably possible;
14. vendor access must be revocable;
15. vendor failure must not silently erase recovery options;
16. continuing use requires continuing justification;
17. urgent procurement does not erase retrospective review;
18. public claims about vendor-backed security must remain accurate and scoped.

3. Scope

This Model applies to:

- prospective vendors;
- active vendors;
- subprocessors;
- affiliates acting as service providers;
- integration partners;
- contractors;
- consultants;
- temporary service providers;
- open-source components;
- commercial software dependencies;
- package maintainers;
- source-code repositories;
- build and deployment pipelines;
- mobile distribution platforms;
- browser extensions used for EquineSync work;
- external AI services;
- payment and banking providers;
- security researchers performing authorized work;
- legal, accounting, and insurance providers receiving protected information;
- vendors used in development, testing, staging, production, support, recovery, and administration.

No dependency is outside governance merely because it is:

- free;
- open source;
- temporary;
- experimental;
- internally recommended;
- bundled with another service;
- activated through a marketplace;
- used only by developers;
- used only during an incident;

- described as a plug-in or connector.

4. Relationship to Other Canon

This Model shall be interpreted together with the cross-canon dependencies identified in Document Control and Required Cross-Canon Dependencies.

Where another constitutional model imposes a more specific or more protective requirement, the more protective requirement shall govern where the provisions can reasonably coexist.

5. Vendor Governance Objectives

Vendor governance shall protect:

- customer confidentiality;
- tenant isolation;
- horse-welfare continuity;
- human safety;
- minors and safeguarding information;
- identity and access boundaries;
- financial integrity;
- authoritative records;
- audit and evidence integrity;
- service availability;
- data portability;
- legal and regulatory compliance;
- public trust;
- vendor exit capability;
- supply-chain integrity.

6. Vendor Lifecycle

Every material vendor relationship shall be governed through these lifecycle stages:

19. need identification;
20. vendor discovery;
21. preliminary classification;
22. due diligence;
23. risk review;
24. architecture review;
25. privacy and data review;
26. legal and contractual review;
27. approval;
28. onboarding;
29. technical integration;
30. validation;
31. activation;
32. continuous monitoring;
33. periodic reassessment;
34. issue remediation;
35. suspension;
36. migration;
37. termination;
38. data return and deletion;
39. residual-access confirmation;

40. evidence retention.

A vendor shall not skip lifecycle stages merely because another department has already purchased or recommended the service.

7. Vendor Inventory

EquineSync shall maintain an authoritative vendor and dependency inventory.

The inventory shall identify, as applicable:

- legal vendor name;
- service name;
- business owner;
- technical owner;
- security owner;
- purpose;
- criticality tier;
- data categories;
- access level;
- affected tenants;
- environments;
- subprocessors;
- geographic processing;
- retention;
- contract dates;
- renewal dates;
- incident contact;
- exit plan;
- last review;
- next review;
- approval status;
- current exceptions;
- evidence location.

Unknown, ownerless, or undocumented production vendors are prohibited.

8. Vendor Categories

Vendors may include:

- infrastructure providers;
- platform providers;
- processors;
- subprocessors;
- independent service providers;
- data providers;
- integration partners;
- professional advisers;
- temporary incident-response vendors;
- software suppliers;
- open-source maintainers;
- package registries;
- deployment providers;
- financial providers;

- communication providers;
- AI providers.

A vendor's category shall not determine risk by itself.

Risk depends on actual access, authority, data, criticality, and dependency.

9. Vendor Risk Tiers

EquineSync shall classify vendors by risk.

At minimum, the following tiers shall apply.

9.1 Tier 1: Critical

A vendor is Critical where failure or compromise could materially affect:

- identity;
- tenant isolation;
- encryption keys;
- production infrastructure;
- horse-welfare continuity;
- payment processing;
- authoritative records;
- backups or recovery;
- large-scale customer data;
- safeguarding information;
- software build integrity.

9.2 Tier 2: High

A vendor is High risk where it:

- processes Confidential or Restricted data;
- has material production access;
- affects customer communications;
- controls significant integrations;
- supports material financial or operational workflows;
- is difficult to replace quickly.

9.3 Tier 3: Moderate

A vendor is Moderate risk where it processes limited noncritical information or supports replaceable internal functions with controlled access.

9.4 Tier 4: Low

A vendor is Low risk where it:

- receives no customer data;
- has no production access;
- cannot affect authoritative systems;
- is readily replaceable;
- creates limited operational impact.

Risk tier shall determine review depth, contract requirements, monitoring, approval, and reassessment frequency.

10. Risk Factors

Vendor classification shall consider:

- data sensitivity;
- data volume;
- tenant reach;
- access privilege;
- system authority;
- operational criticality;
- horse-welfare dependency;
- minors or safeguarding impact;
- financial authority;
- identity dependency;
- encryption-key access;
- backup or recovery role;
- subprocessor use;
- geographic processing;
- incident history;
- security maturity;
- contractual protection;
- concentration risk;
- replacement difficulty;
- data portability;
- lock-in;
- financial stability;
- technical transparency;
- open-source dependency health;
- customer-facing visibility.

11. Criticality and Security Risk Are Distinct

A vendor may be:

- operationally critical but handle little sensitive data;
- highly sensitive but not operationally critical;
- both critical and sensitive;
- low sensitivity but high supply-chain authority.

EquineSync shall assess:

41. security risk;
42. privacy risk;
43. operational criticality;
44. financial risk;
45. legal risk;
46. concentration risk;
47. exit risk.

One score shall not conceal materially different risk types.

12. Need and Purpose Validation

Before vendor review begins, the requesting owner shall identify:

- business need;
- intended purpose;
- expected users;
- required data;
- required permissions;
- alternatives considered;
- expected duration;
- whether existing approved tools can satisfy the need.

EquineSync shall not introduce a new vendor merely because:

- it is fashionable;
- it is free;
- a team member prefers it;
- it duplicates an existing tool;
- a marketplace offers one-click installation.

13. Data Minimization

Vendors shall receive only the minimum information necessary for the approved purpose.

Review shall consider whether:

- raw data is required;
- masked data is sufficient;
- tokens can replace credentials;
- aggregate data is sufficient;
- synthetic data can be used;
- field-level access can be narrowed;
- access can be time limited;
- data can remain within EquineSync.

A vendor shall not receive an entire tenant dataset where a smaller scope is sufficient.

14. Access Minimization

Vendor access must be:

- purpose bound;
- tenant scoped;
- environment scoped;
- time limited where feasible;
- individually attributable;
- strongly authenticated;
- logged;
- reviewable;
- revocable.

Vendor personnel shall not receive standing broad access merely because support access may occasionally be needed.

15. Vendor Due Diligence

Due diligence shall be proportionate to risk.

Review may include:

- security program;

- access controls;
- encryption;
- key management;
- personnel security;
- incident response;
- vulnerability management;
- secure development;
- audit logging;
- resilience;
- backup and recovery;
- data retention;
- deletion;
- privacy;
- subprocessors;
- geographic processing;
- certifications;
- independent assessments;
- penetration testing;
- business continuity;
- financial stability;
- insurance;
- litigation or enforcement history;
- breach history;
- customer references;
- exit capability.

16. Evidence Quality

Vendor claims shall be evaluated according to evidence quality.

Evidence may include:

- independent audit reports;
- certification reports;
- penetration-test summaries;
- security questionnaires;
- architecture documentation;
- contractual commitments;
- incident history;
- trust-center materials;
- technical validation;
- customer references;
- direct demonstrations.

Marketing language alone is weak evidence.

A certification shall not be treated as proof that:

- every service is covered;
- EquineSync's configuration is secure;
- tenant isolation is adequate;
- no breach can occur;
- all contractual requirements are satisfied.

17. Security Questionnaires

Security questionnaires may support review but shall not replace:

- architecture analysis;
- contract review;
- technical testing;
- incident-history review;
- service-specific evidence.

Responses must be:

- current;
- service specific;
- attributable;
- preserved.

Material contradictions shall be resolved before approval.

18. Certifications and Audits

Certifications or audit reports shall be evaluated for:

- scope;
- service coverage;
- time period;
- exceptions;
- complementary customer controls;
- auditor qualifications;
- subprocessor treatment;
- control failures;
- remediation status.

Expired, irrelevant, or out-of-scope reports shall not be represented as current assurance.

19. Architecture Review

Architecture review shall determine:

- where data flows;
- what systems are reached;
- how authentication occurs;
- what permissions are granted;
- where data is stored;
- whether data leaves a region;
- how tenant isolation is preserved;
- how the vendor is disabled;
- how data is returned;
- how credentials are rotated;
- how failure affects EquineSync.

No vendor shall be approved solely through legal or procurement review where technical integration creates material risk.

20. Privacy Review

Privacy review shall evaluate:

- data categories;
- purposes;
- lawful basis;
- retention;
- deletion;
- data-subject rights;
- minors;
- safeguarding;
- international transfers;
- subprocessors;
- government access;
- vendor reuse;
- deidentification;
- customer notice;
- contract requirements.

Vendor use of data for unrelated analytics, advertising, profiling, or product improvement requires separate constitutional authority and shall not be implied by ordinary service terms.

21. AI and Model Providers

AI providers require specialized review.

Review shall address:

- model-provider identity;
- model and service type;
- prompt and output retention;
- provider training;
- human review;
- tenant isolation;
- tool access;
- data location;
- subprocessors;
- model logging;
- deletion;
- contractual restrictions;
- model changes;
- provider exit;
- safety controls.

Customer operational data, including financial, health-related, and horse-care information, shall not be used to train shared or general models.

No provider shall receive broader data than the active user and workflow are authorized to access.

22. Payment and Financial Providers

Payment, banking, and financial vendors require specialized review.

Review shall address:

- tokenization;
- payment-data handling;
- prohibited storage;
- fraud controls;

- payout-change controls;
- financial reconciliation;
- dispute handling;
- incident notification;
- availability;
- reserve or account-freeze risk;
- geographic processing;
- contract termination;
- data portability.

Provider-hosted collection should be used for sensitive payment credentials where reasonably possible.

23. Identity Providers

Identity providers require Critical-tier review.

Review shall address:

- authentication assurance;
- multifactor authentication;
- account recovery;
- session management;
- tenant isolation;
- administrator access;
- logging;
- availability;
- regional failure;
- export;
- migration;
- incident notification;
- lockout and suspension risk.

EquineSync shall maintain contingency planning for identity-provider failure or termination.

24. Communication Providers

Email, SMS, push, messaging, and notification providers shall be reviewed for:

- message confidentiality;
- recipient validation;
- minors and guardian rules;
- delivery evidence;
- retention;
- message content exposure;
- account takeover;
- sender authentication;
- emergency availability;
- vendor reuse of content.

Communication providers shall not receive more message content than necessary.

25. Backup and Recovery Providers

Backup and recovery providers shall be reviewed for:

- encryption;

- key separation;
- immutability;
- access controls;
- recovery testing;
- regional location;
- deletion;
- incident notification;
- ransomware resilience;
- exit capability;
- data-return format.

A provider's backup claim shall not substitute for EquineSync restoration testing.

26. Security-Testing Providers

Penetration testers, forensic firms, and security consultants may receive extraordinary access.

Their engagement must define:

- scope;
- environment;
- methods;
- prohibited actions;
- customer-data handling;
- evidence custody;
- retention;
- confidentiality;
- incident reporting;
- deletion;
- personnel access;
- subcontractors.

Testing authority must be written and time limited.

27. Professional Service Providers

Legal, accounting, insurance, and consulting providers receiving protected information shall be governed according to actual access.

Professional status does not eliminate the need for:

- confidentiality;
- minimum-necessary disclosure;
- secure transfer;
- retention limits;
- access control;
- incident notice;
- deletion or return.

28. Contractor and Consultant Access

Contractors and consultants shall not receive employee-equivalent access by default.

Their access shall be:

- role specific;
- time limited;

- individually assigned;
- reviewed;
- revoked at engagement end.

Contract terms shall address:

- confidentiality;
- work product;
- security;
- acceptable use;
- incident reporting;
- return of property;
- data deletion;
- access termination.

29. Subprocessors

Vendors shall disclose subprocessors appropriate to the service and risk.

EquineSync shall evaluate:

- subprocessor identity;
- function;
- location;
- data access;
- security posture;
- incident obligations;
- replacement rights;
- objection rights;
- deletion obligations.

A vendor may not use a subprocessor to obtain rights or access the vendor itself does not possess.

30. Fourth-Party Risk

Critical vendor review shall consider dependencies that may not be direct subprocessors, including:

- cloud infrastructure;
- identity services;
- package registries;
- certificate authorities;
- communication networks;
- content-delivery networks;
- model providers;
- data centers.

Fourth-party concentration may create risk even where no direct contract exists.

31. Geographic Processing

EquineSync shall document material geographic locations where vendors:

- store data;
- access data;
- manage keys;
- provide support;

- perform recovery;
- use subprocessors.

Regional commitments shall not be claimed where vendor personnel or subprocessors can routinely access data from other locations.

32. International Transfers

International data transfers shall follow controlling privacy canon.

Review shall address:

- transfer mechanism;
- jurisdiction;
- government-access risk;
- subprocessor locations;
- supplementary safeguards;
- customer commitments;
- exit options.

Vendor convenience shall not substitute for a lawful transfer basis.

33. Contractual Security Requirements

Material vendor agreements should address, as appropriate:

- permitted purpose;
- confidentiality;
- minimum-necessary access;
- security controls;
- encryption;
- key management;
- incident notice;
- cooperation;
- subprocessors;
- data location;
- retention;
- deletion;
- data return;
- audit evidence;
- continuity;
- termination;
- insurance;
- liability;
- legal requests;
- AI training restrictions;
- ownership;
- service levels.

Contract requirements shall be proportionate to risk and actual service function.

34. Incident Notification Terms

Critical and High-risk vendors should be contractually required to notify EquineSync promptly of incidents that affect or may reasonably affect:

- EquineSync data;
- EquineSync systems;
- customer operations;
- tenant isolation;
- credentials;
- keys;
- availability;
- financial activity;
- horse-welfare continuity.

Vendor notice obligations should require ongoing material updates, not merely one initial notice.

35. Vendor Incident Cooperation

Contracts should require appropriate cooperation, including:

- preservation of evidence;
- relevant logs;
- scope information;
- affected data categories;
- subprocessor information;
- containment status;
- remediation;
- customer-notice support;
- regulator support;
- deletion or return confirmation.

Vendor silence or delay shall increase vendor risk.

36. Data Use Restrictions

Vendors shall not use EquineSync data for:

- advertising;
- sale;
- cross-context profiling;
- unrelated product development;
- shared-model training;
- competitive intelligence;
- unrelated benchmarking;
- resale;
- data brokerage.

Permitted operational telemetry must be:

- minimum necessary;
- appropriately aggregated or deidentified;
- governed by contract;
- retained narrowly;
- protected from reidentification.

37. Government Requests to Vendors

Vendor terms should require, where legally permissible:

- prompt notice of government or legal requests;

- review of validity and scope;
- minimum-necessary disclosure;
- challenge of overbroad requests where reasonable;
- documentation of disclosures.

A vendor shall not voluntarily disclose broader EquineSync data than legally required.

38. Data Ownership and Control

Vendor possession or processing does not transfer ownership of EquineSync or customer data.

Contracts shall distinguish:

- ownership;
- stewardship;
- processing authority;
- intellectual property;
- service telemetry;
- derived data;
- deidentified data;
- model outputs;
- configuration data.

Vendor-generated metadata shall not become an uncontrolled pathway to reconstruct customer operations.

39. Data Retention

Vendor retention must be:

- purpose based;
- documented;
- contractually controlled where material;
- consistent with EquineSync retention governance;
- limited after termination.

Vendors shall not retain data indefinitely merely because their systems make deletion difficult.

40. Data Deletion and Return

Vendor exit shall address:

- data return;
- format;
- completeness;
- deletion;
- backup expiration;
- subprocessor deletion;
- credential revocation;
- confirmation;
- residual legal retention.

Deletion claims must distinguish:

- active deletion;
- backup expiration;
- legal retention;
- irreversible destruction.

A vendor's unsupported statement that data was deleted shall not automatically close the obligation.

41. Vendor Onboarding

Before activation, onboarding shall verify:

- approval;
- executed agreement;
- technical owner;
- business owner;
- access scope;
- data flow;
- security configuration;
- logging;
- credentials;
- incident contact;
- renewal date;
- exit plan;
- validation status.

Procurement completion alone does not authorize production activation.

42. Credential and Secret Provisioning

Vendor credentials shall be:

- environment specific;
- individually or service assigned;
- least privilege;
- stored in approved secret-management systems;
- rotated;
- revocable;
- monitored.

Credentials shall not be:

- shared through uncontrolled channels;
- committed to repositories;
- embedded in public applications;
- reused across unrelated vendors;
- retained after termination.

43. Vendor Administrative Access

Vendor administrative access to EquineSync systems shall ordinarily be:

- just in time;
- purpose bound;
- time limited;
- approved;
- strongly authenticated;
- logged;
- automatically expired.

Standing vendor administrator access requires documented justification and heightened review.

44. Support Access

Vendor support personnel shall not receive unrestricted access to customer content.

Support access shall be limited by:

- tenant;
- record;
- time;
- purpose;
- approved case.

Customer or EquineSync authorization shall be obtained as required by controlling access canon.

45. Integration Permissions

Each integration shall have a documented permission model identifying:

- data read;
- data written;
- actions performed;
- tenant scope;
- user authority;
- token scope;
- webhook authority;
- error behavior;
- revocation method.

Read access shall not imply write authority.

Write authority shall not imply deletion or administration authority.

46. Webhook and Event Security

Vendor webhooks and event channels shall address:

- authentication;
- signature validation;
- replay protection;
- rate limiting;
- source validation;
- tenant routing;
- logging;
- failure handling.

Unsigned or unauthenticated vendor events shall not be trusted for authoritative mutation without additional validation.

47. API Security

Vendor API integrations shall use:

- scoped credentials;
- secure transport;
- rotation;
- rate limits;
- error handling;
- audit logging;

- tenant-aware authorization;
- input validation;
- output validation.

Direct vendor identifiers shall not bypass EquineSync authorization.

48. Vendor Validation Before Activation

Before production activation, EquineSync shall validate:

- authentication;
- authorization;
- tenant isolation;
- data minimization;
- error handling;
- logging;
- revocation;
- retention;
- deletion;
- failure behavior;
- support access;
- incident contact.

Critical integrations shall include prohibited-action testing, not merely successful happy-path testing.

49. Change Notification

Critical vendors should provide reasonable notice of material changes involving:

- subprocessors;
- processing location;
- security controls;
- APIs;
- authentication;
- retention;
- service architecture;
- ownership;
- terms;
- end of life.

Material changes shall trigger reassessment where risk may change.

50. Continuous Monitoring

Vendor monitoring may include:

- security advisories;
- incident notices;
- status pages;
- audit-report updates;
- certification expiration;
- service changes;
- subprocessor changes;
- breach history;
- financial health;

- performance;
- support responsiveness;
- public vulnerability disclosures;
- regulatory action.

Monitoring shall be proportionate to risk.

51. Periodic Reassessment

Critical and High-risk vendors shall be reassessed periodically.

Reassessment shall consider:

- current data and access;
- architecture changes;
- incident history;
- evidence currency;
- contract status;
- subprocessor changes;
- retained exceptions;
- exit readiness;
- concentration risk.

Renewal shall not be automatic where material review is overdue.

52. Vendor Performance and Control Failures

Material vendor failures shall be tracked.

Examples include:

- repeated outages;
- delayed incident notice;
- failed deletion;
- unresolved vulnerabilities;
- access overreach;
- unsupported claims;
- audit failures;
- missed service levels;
- poor recovery performance;
- unapproved subprocessors.

Recurring failures may require:

- corrective action;
- access reduction;
- suspension;
- replacement;
- termination.

53. Vendor Exceptions

A vendor exception must identify:

- unmet requirement;
- business need;
- risk;

- compensating controls;
- owner;
- approver;
- duration;
- review date;
- exit trigger.

Exceptions shall not silently waive:

- tenant isolation;
- safeguarding protections;
- shared-model training prohibitions;
- audit integrity;
- incident notice;
- encryption-key protection;
- legal holds;
- production authority gates.

54. Concentration Risk

EquineSync shall identify concentration risk where multiple critical functions depend on:

- one vendor;
- one cloud provider;
- one region;
- one identity provider;
- one payment provider;
- one package registry;
- one communication channel;
- one build system;
- one key-management service.

Concentration risk shall be reduced, monitored, or explicitly accepted.

55. Lock-In and Exit Risk

Vendor review shall assess:

- proprietary formats;
- data export;
- API portability;
- egress cost;
- key portability;
- contract restrictions;
- migration time;
- replacement availability;
- customer disruption;
- retained vendor data.

Critical vendors require a realistic exit plan, not a ceremonial paragraph in a risk register.

56. Exit Plan

A Critical vendor exit plan shall identify:

- trigger conditions;

- replacement options;
- data export;
- data validation;
- credential revocation;
- key transition;
- service continuity;
- customer communication;
- contract termination;
- residual data;
- evidence;
- rollback.

Exit plans shall be reviewed when architecture or vendor conditions change.

57. Emergency Vendor Use

A vendor may be engaged urgently during an incident or disaster where delay would increase harm.

Emergency use must be:

- narrowly scoped;
- time limited;
- approved by emergency authority;
- documented;
- protected by available confidentiality terms;
- reviewed after stabilization.

Emergency use does not create permanent approval.

Retrospective due diligence and offboarding are mandatory.

58. Shadow IT

Use of unapproved vendors for EquineSync data or operations is prohibited.

Shadow IT includes:

- personal file storage;
- personal AI accounts;
- unapproved messaging;
- unapproved analytics;
- personal code repositories;
- unapproved browser extensions;
- unapproved automation platforms;
- personal email for protected records.

EquineSync shall provide practical approved alternatives so security does not become a maze that invites side doors.

59. Open-Source Software

Open-source software is part of the supply chain.

Review shall consider:

- maintainer health;
- release activity;
- licensing;
- vulnerability history;

- dependency depth;
- package authenticity;
- download source;
- replacement options;
- transitive dependencies;
- abandonment risk.

Open source shall not be treated as automatically safer or automatically riskier than commercial software.

60. Software Bill of Materials

EquineSync shall maintain or be able to produce an appropriate inventory of material software components and dependencies.

The inventory should identify:

- component;
- version;
- source;
- license;
- direct or transitive status;
- affected systems;
- known vulnerabilities;
- owner;
- replacement path.

A software bill of materials may support this requirement.

61. Dependency Management

Dependencies shall be:

- version controlled;
- reviewed;
- scanned;
- updated through governed changes;
- removed when unused;
- monitored for vulnerabilities.

Unpinned, abandoned, or untrusted dependencies require heightened review.

62. Package Registries

Package registries shall be governed for:

- account security;
- namespace protection;
- package authenticity;
- typosquatting risk;
- dependency confusion;
- token protection;
- publishing authority;
- retention;
- incident response.

Production builds shall not rely on uncontrolled package sources without validation.

63. Source-Code Repositories

Source-code platforms shall receive Critical or High-risk review.

Controls shall include:

- multifactor authentication;
- least privilege;
- branch protection;
- audit logs;
- secret scanning;
- review requirements;
- account revocation;
- token management;
- backup or export capability.

Repository access shall not silently continue after employment or engagement ends.

64. Build and Deployment Pipelines

Build and deployment systems are part of the production trust boundary.

Controls shall address:

- source integrity;
- build identity;
- secrets;
- artifact provenance;
- approval;
- environment separation;
- logging;
- rollback;
- unauthorized pipeline change.

A compromised pipeline may create a security incident even where source code appears unchanged.

65. Build Artifact Provenance

EquineSync should preserve evidence linking production artifacts to:

- source revision;
- build process;
- dependency versions;
- build environment;
- approving release;
- signing identity;
- deployment.

Unverifiable artifacts shall not be promoted to production without explicit exception and validation.

66. Artifact Signing

Signing or equivalent integrity controls should be considered for:

- application packages;
- containers;
- release artifacts;

- mobile builds;
- updates;
- critical configuration.

Signing keys shall follow controlling encryption and key-management canon.

67. Container and Image Sources

Container images shall come from approved sources.

Controls shall address:

- base-image provenance;
- vulnerability scanning;
- immutability;
- registry access;
- signing;
- tag mutability;
- secrets;
- unsupported packages.

Mutable tags shall not be treated as reliable evidence of exact production content.

68. Mobile Application Supply Chain

Mobile application distribution shall address:

- developer accounts;
- signing certificates;
- provisioning;
- store access;
- release approval;
- account recovery;
- compromised credentials;
- emergency release;
- rollback limitations.

Mobile distribution credentials shall be treated as Critical.

69. Browser Extensions and Client-Side Dependencies

Browser extensions and client-side third-party scripts may access sensitive page content.

Their use shall be minimized and reviewed for:

- data collection;
- script integrity;
- update control;
- content access;
- supply-chain compromise;
- retention;
- advertising behavior.

Third-party scripts shall not receive authenticated customer data without governed necessity.

70. Telemetry and Analytics Vendors

Telemetry vendors shall receive only the data necessary for:

- security;
- performance;
- reliability;
- governed product analysis.

Telemetry shall not expose:

- passwords;
- secrets;
- full payment data;
- safeguarding content;
- unnecessary horse or person details;
- unrestricted message content.

Security telemetry shall not be repurposed for advertising.

71. Data Brokers and Advertising Vendors

EquineSync prohibits vendor relationships whose purpose is:

- sale of personal data;
- behavioral advertising;
- cross-context profiling;
- unrelated data monetization;
- data brokerage.

This prohibition applies even where consent language could arguably be drafted to permit such use.

72. Vendor Incident Response

Vendor incidents shall be managed under the Master Security Incident Response and Disclosure Model.

EquineSync shall independently assess:

- scope;
- data affected;
- tenant impact;
- ongoing access;
- vendor credibility;
- containment;
- customer notice;
- regulator notice;
- credential rotation;
- service suspension;
- exit need.

Vendor assurance does not remove EquineSync's responsibility to protect customers.

73. Vendor Suspension

Vendor access or service may be suspended where:

- compromise is suspected;
- material controls fail;

- data use exceeds authority;
- notice obligations are breached;
- continued operation creates greater risk;
- contractual terms expire;
- the vendor refuses necessary cooperation.

Suspension must be:

- proportionate;
- documented;
- reviewable;
- coordinated with continuity planning.

74. Vendor Termination

Termination authority must be formally assigned.

Termination planning shall address:

- customer impact;
- service continuity;
- data return;
- data deletion;
- credential revocation;
- key transition;
- contract obligations;
- legal hold;
- evidence preservation;
- subprocessor access;
- public claims;
- replacement.

Vendor termination shall not be considered complete until residual access and data obligations are addressed.

75. Offboarding

Vendor offboarding shall include:

- disable integrations;
- revoke tokens;
- remove accounts;
- rotate shared secrets;
- recover data;
- confirm deletion;
- update inventories;
- update dependency maps;
- preserve required evidence;
- notify affected owners;
- terminate support access.

A contract end date alone does not terminate technical access.

76. Data Exit Validation

Returned or migrated data shall be validated for:

- completeness;
- format;
- integrity;
- tenant mapping;
- record history;
- attachments;
- audit evidence;
- financial reconciliation;
- access controls.

A successful download does not automatically prove successful exit.

77. Vendor Bankruptcy or Disappearance

Critical vendor planning shall consider:

- insolvency;
- acquisition;
- abrupt shutdown;
- employee abandonment;
- inaccessible support;
- frozen accounts;
- loss of hosted data;
- source-code unavailability;
- expired certificates.

Exit plans shall not depend entirely on vendor cooperation during collapse.

78. Mergers and Ownership Changes

Material vendor ownership changes may trigger reassessment.

Review shall consider:

- new parent company;
- changed jurisdiction;
- revised privacy practices;
- changed subprocessors;
- competitive conflicts;
- financial stability;
- data use;
- contract assignment;
- exit rights.

Continued use shall not be automatic where the trust boundary materially changes.

79. Vendor Records and Evidence

EquineSync shall preserve appropriate evidence of:

- due diligence;
- approvals;
- contracts;
- data flows;
- access;
- incidents;

- reassessments;
- exceptions;
- termination;
- deletion;
- exit validation.

Vendor records shall follow controlling retention and legal-hold governance.

80. Vendor Metrics

Governance metrics may include:

- vendors by tier;
- overdue reviews;
- expired contracts;
- expired assurance reports;
- unresolved vendor findings;
- unapproved subprocessors;
- vendor incidents;
- overdue deletion confirmations;
- dormant integrations;
- shared credentials;
- missing exit plans;
- concentration exposure;
- shadow IT reports;
- open-source vulnerabilities;
- unsupported dependencies.

Metrics shall not substitute for substantive review.

81. Vendor Risk Acceptance

Material retained vendor risk must identify:

- risk;
- business justification;
- affected systems;
- affected data;
- compensating controls;
- owner;
- approver;
- duration;
- review date;
- exit trigger.

High residual risk involving tenant isolation, safeguarding, encryption keys, payment authority, or customer-data training requires Founder review unless expressly delegated.

82. Customer Disclosure

EquineSync shall disclose vendors or subprocessors to customers where required by:

- law;
- contract;
- privacy notice;

- data-processing terms;
- enterprise commitments.

Disclosures must be:

- accurate;
- current;
- appropriately scoped;
- corrected when vendor use changes.

Vendor lists shall not imply that every listed vendor accesses every customer's data.

83. Trust Claims Involving Vendors

EquineSync shall not claim that it is:

- secure because a vendor is secure;
- compliant solely because a vendor is certified;
- multi-region without complete supporting architecture;
- end-to-end encrypted based solely on vendor encryption;
- resilient based solely on vendor uptime claims;
- private where vendor reuse contradicts the claim.

Vendor-backed trust claims require evidence covering EquineSync's actual configuration and use.

84. Customer Choice and Optional Integrations

Optional integrations shall be clearly distinguished from required platform providers.

Where customers activate optional integrations, EquineSync shall identify:

- information shared;
- permissions granted;
- vendor relationship;
- revocation method;
- customer responsibilities;
- relevant privacy effects.

Customer activation shall not waive EquineSync's duty to design a secure integration.

85. Prohibited Vendor Practices

EquineSync prohibits:

48. activating production vendors without approval;
49. unknown or ownerless production vendors;
50. granting unrestricted standing vendor access;
51. allowing vendors to train shared models on customer operational data;
52. selling or licensing customer data;
53. vendor behavioral advertising using customer data;
54. unapproved subprocessors with material access;
55. vendor credentials committed to source control;
56. shared vendor administrator accounts;
57. accepting marketing claims as sole security evidence;
58. relying solely on certification logos;
59. automatic renewal without required reassessment;
60. shadow IT involving protected data;
61. unreviewed production browser extensions;
62. using personal AI accounts for customer data;

63. package installation from untrusted sources;
64. unsigned or unverifiable production artifacts where integrity controls are required;
65. dependency updates outside release governance;
66. leaving vendor access active after termination;
67. claiming deletion without evaluating backups and subprocessors;
68. allowing vendor telemetry to become advertising data;
69. approving a vendor without considering exit risk;
70. treating vendor failure as solely the vendor's responsibility;
71. allowing one vendor to hold irreplaceable data without an exit path;
72. allowing emergency vendor use to become permanent without review;
73. accepting unresolved contradictions in vendor evidence;
74. restoring vendor access after an incident without revalidation;
75. treating open-source components as outside supply-chain governance;
76. using production data in vendor demonstrations without authorization;
77. allowing vendors to modify authoritative records beyond their approved function.

86. Required Implementation Artifacts

Before production implementation, EquineSync shall produce at least:

- Vendor and Dependency Inventory;
- Vendor Risk Classification Standard;
- Vendor Due Diligence Standard;
- Vendor Security Questionnaire;
- Vendor Approval Matrix;
- Critical Vendor Review Checklist;
- Privacy and Data Flow Assessment;
- Subprocessor Register;
- Vendor Contract Requirement Matrix;
- Vendor Access Standard;
- Integration Permission Register;
- Vendor Credential Register;
- Vendor Monitoring Plan;
- Vendor Reassessment Schedule;
- Vendor Incident Playbook;
- Vendor Suspension Procedure;
- Vendor Exit and Offboarding Standard;
- Critical Vendor Exit Plans;
- Concentration Risk Register;
- Software Bill of Materials Procedure;
- Open-Source Dependency Standard;
- Source Repository Security Standard;
- Build and Artifact Provenance Standard;
- Package Registry Standard;
- Supply-Chain Incident Playbook;
- Shadow IT Standard;
- Emergency Vendor Procedure;
- Vendor Exception Register.

87. Required Validation

Before production activation, EquineSync shall validate:

- vendor approval status;
- contract completion;
- data minimization;
- access scope;
- tenant isolation;
- credential storage;
- revocation;
- logging;
- incident contact;
- subprocessors;
- data location;
- retention;
- deletion;
- continuity;
- exit capability;
- integration failure behavior;
- webhook validation;
- API authorization;
- support access;
- provider outage response;
- vendor offboarding;
- software dependency integrity;
- build artifact provenance.

Validation must include both authorized and prohibited scenarios.

88. Test Categories

Testing should include:

78. vendor authentication tests;
79. vendor authorization tests;
80. tenant-isolation tests;
81. integration revocation tests;
82. token-scope tests;
83. support-access expiration tests;
84. webhook signature tests;
85. replay tests;
86. vendor outage tests;
87. provider termination tests;
88. data export tests;
89. data deletion tests;
90. subprocessor change tests;
91. credential rotation tests;
92. dependency-confusion tests;
93. package-integrity tests;
94. artifact-provenance tests;
95. source-repository access tests;
96. pipeline-compromise simulations;
97. vendor incident-notification exercises;
98. exit-plan exercises;
99. shadow IT discovery tests;
100. AI provider data-retention tests;
101. payment-provider reconciliation tests.

89. Review and Amendment

This Model shall be reviewed following:

- a material vendor incident;
- supply-chain compromise;
- critical provider failure;
- material subprocessor change;
- significant acquisition or ownership change;
- major AI-provider change;
- payment-provider change;
- identity-provider change;
- cloud-provider change;
- public launch preparation;
- enterprise security review;
- significant regulatory change;
- Founder direction.

Operational standards may be updated without constitutional amendment where they do not weaken this Model or alter reserved authority.

90. Conflict and Interpretation

Where provisions conflict:

- 102. applicable law and binding legal orders govern where controlling;
- 103. adopted constitutional canon governs subordinate vendor policy;
- 104. the more specific and more protective requirement controls;
- 105. tenant isolation, safeguarding, evidence integrity, and horse-welfare continuity shall not be silently weakened;
- 106. Founder interpretation governs unresolved constitutional ambiguity;
- 107. ambiguity does not create authority to activate, disclose, contract, migrate, or terminate.

91. Authority Boundary

This Model establishes constitutional governance only.

It does not authorize:

- vendor selection;
- contract execution;
- vendor approval;
- production activation;
- integration activation;
- credential provisioning;
- data disclosure;
- subprocessor approval;
- vendor testing against production;
- vendor suspension;
- vendor termination;
- data migration;
- emergency vendor engagement;
- public vendor claims;
- production release;
- public launch.

Each action requires the authority, planning, validation, and release gate required by controlling canon.

92. Adoption and Lock State

Founder acceptance establishes this document as controlling constitutional text for EquineSync vendor security and supply-chain governance.

Founder acceptance does not itself establish repository adoption, terminal lock, implementation readiness, production authority, vendor activation, contract execution, data disclosure, or public launch authority.

The controlled lifecycle remains:

FOUNDER_ACCEPTED -> CONTROLLED_ADOPTION -> REPOSITORY_VERIFICATION -> LOCKED

All implementation and production actions remain separately gated.

93. Final Governance State

DOCUMENT: MASTER_VENDOR_SECURITY_AND_SUPPLY_CHAIN_MODEL_V2_0

DOCUMENT_TYPE: TIER_3_FOUNDATIONAL_DOMAIN_CANON

PARENT_CANON: MASTER_SECURITY_AND_TRUST_MODEL_V2_0

CURRENT_STATUS: FOUNDER_ACCEPTED_CONTROLLED_ADOPTION_AND_LOCK_PENDING

CONSTITUTIONAL_AUTHORITY: CONTROLLING_FOUNDER_APPROVED_TEXT

CANON_LOCK_AUTHORITY: FALSE

IMPLEMENTATION_AUTHORITY: FALSE

VENDOR_APPROVAL_AUTHORITY: FALSE

CONTRACT_EXECUTION_AUTHORITY: FALSE

VENDOR_ACTIVATION_AUTHORITY: FALSE

INTEGRATION_ACTIVATION_AUTHORITY: FALSE

DATA_DISCLOSURE_AUTHORITY: FALSE

VENDOR_MIGRATION_AUTHORITY: FALSE

VENDOR_TERMINATION_AUTHORITY: FALSE

PRODUCTION_AUTHORITY: FALSE

PUBLIC_TRUST_CLAIM_AUTHORITY: FALSE

PUBLIC_LAUNCH_AUTHORITY: FALSE

NEXT_GOVERNANCE_STEP: SECURITY_AND_TRUST_CANON_PACKAGE_RECONCILIATION

Founder Acceptance Record

Founder determination: Accepted

Founder acceptance date: July 13, 2026

Acceptance effect: Controlling constitutional text; controlled adoption and repository lock remain pending.

Implementation effect: None. All implementation, provider activation, contract execution, data disclosure, migration, production mutation, trust-claim, and public-launch authority remain false.